Segurança de Dados

MCTA023-17

Apresentação da Disciplina
Introdução a Segurança de Dados

Profª Denise Goya

Roteiro

- Apresentação da disciplina
  - Objetivos
  - Avaliação
  - Datas importantes e Plano de Aulas
  - Referências
- Introdução a Segurança de dados
  - Conceitos
- Leituras e Exercícios

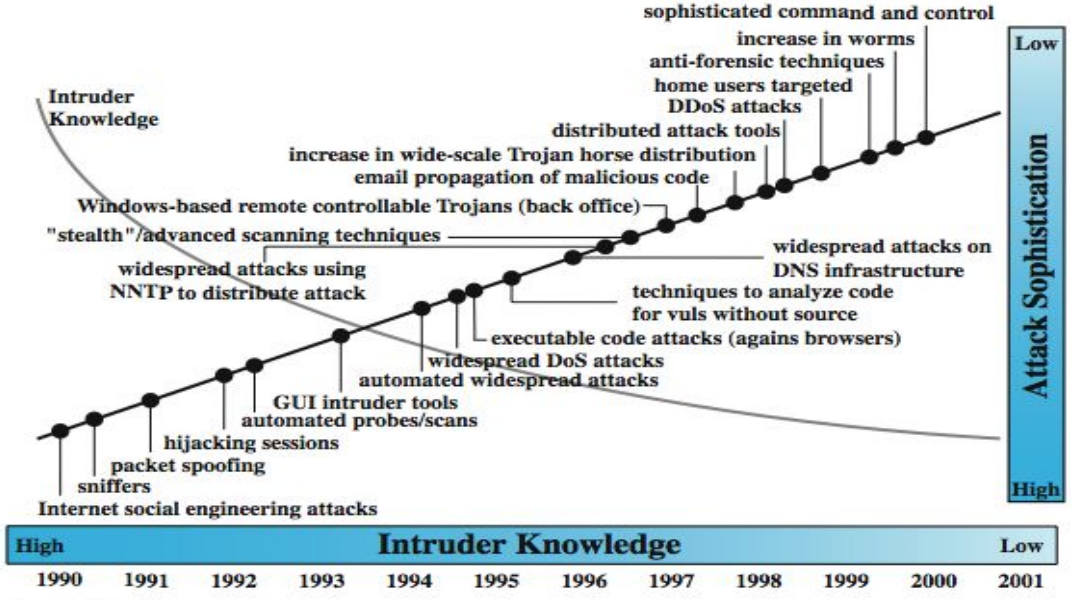
Apresentação da disciplina

Por que aprender

Segurança de Dados?

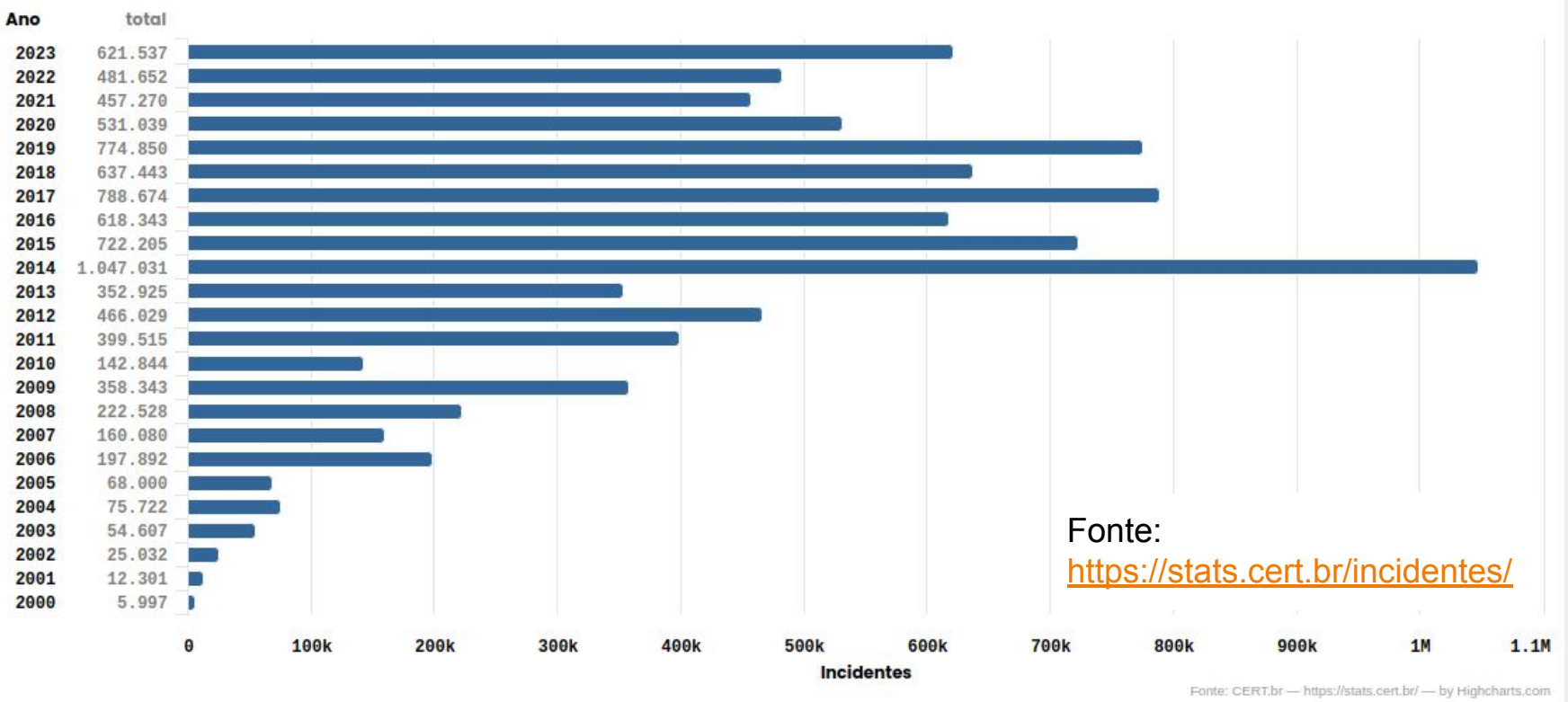
Motivação

Gráfico de Cert: enquanto os ataques a segurança da informação aumentaram em sofisticação, o conhecimento necessário para empreendê-los decresceu



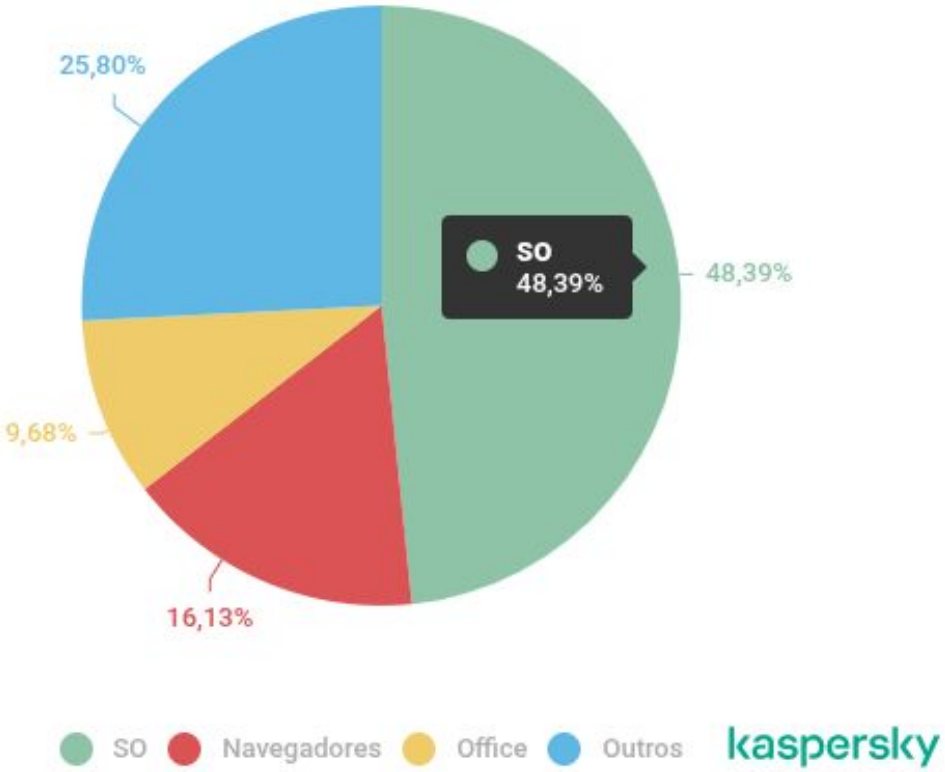
Motivação

Gráfico de Cert.br: incidentes por ano é alto



Fonte: https://stats.cert.br/incidentes/

Ameaças no dia a dia dos usuários

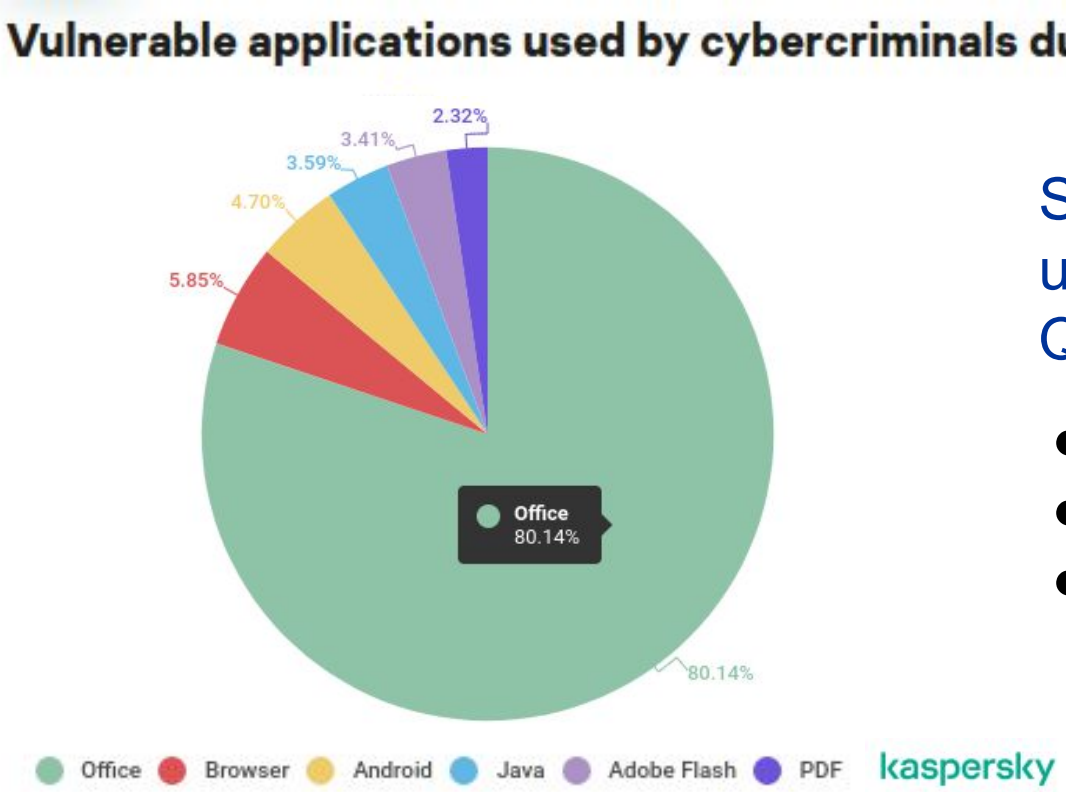


Categorias mais visadas para exploração em Q3.2025:

- Sistemas operacionais
- Navegadores
- Office

Fonte: https://securelist.com.br/vulnerabilities-and-exploits-in-q3-2025/913/

Ameaças no dia a dia dos usuários



Software vulneráveis mais usados no cibercrime no Q3.2023:

- pacotes Office
- Navegadores
- aplicativos Android

Fonte: https://securelist.com/it-threat-evolution-q3-2023-non-mobile-statistics/111228/

Ameaça em mobile: propagandas, troia

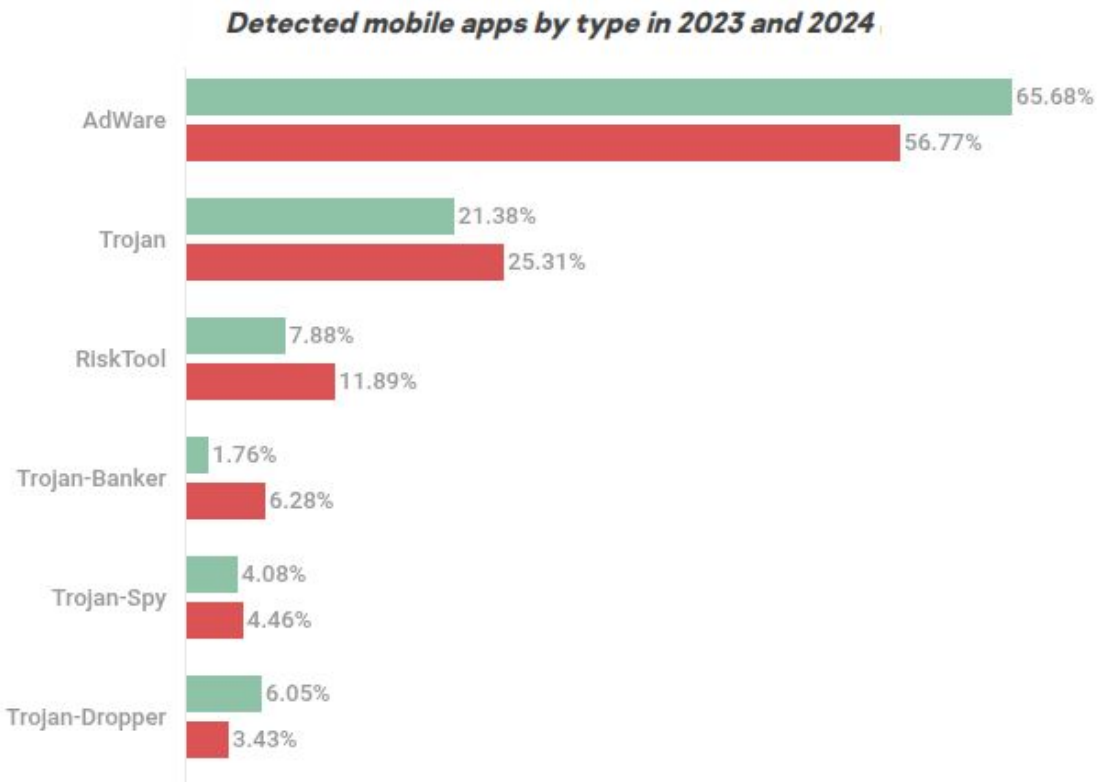


Gráfico mostra aumento de malwares via propagandas e cavalos de Troia

Fonte: https://securelist.com/mobile-threat-report-2024/115494/

Ameaça em mobile banking

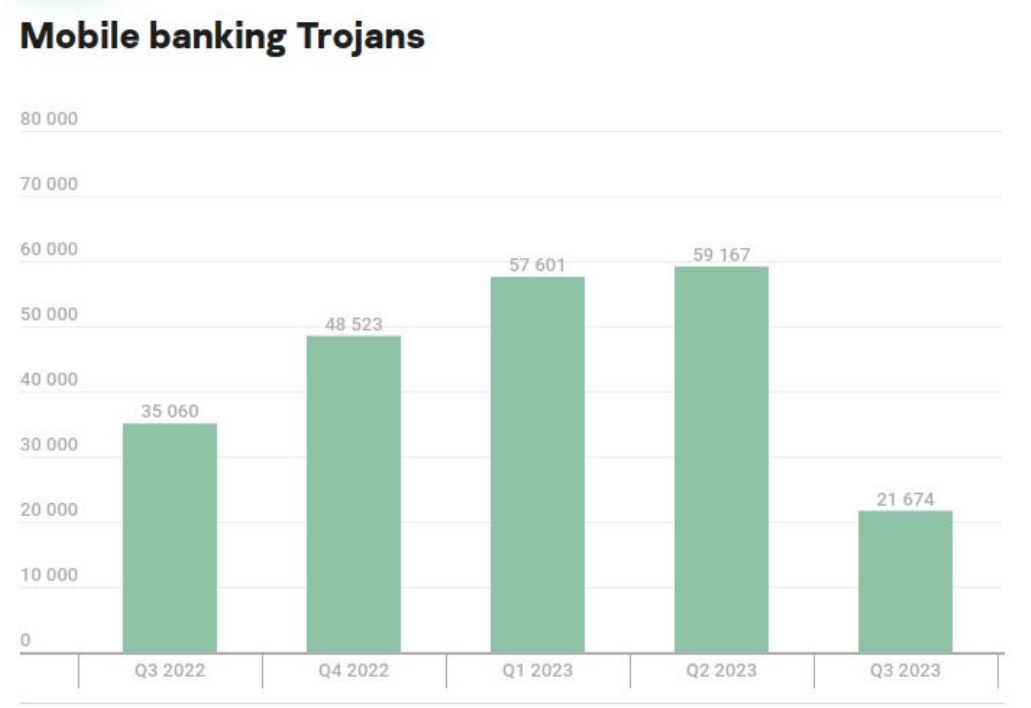
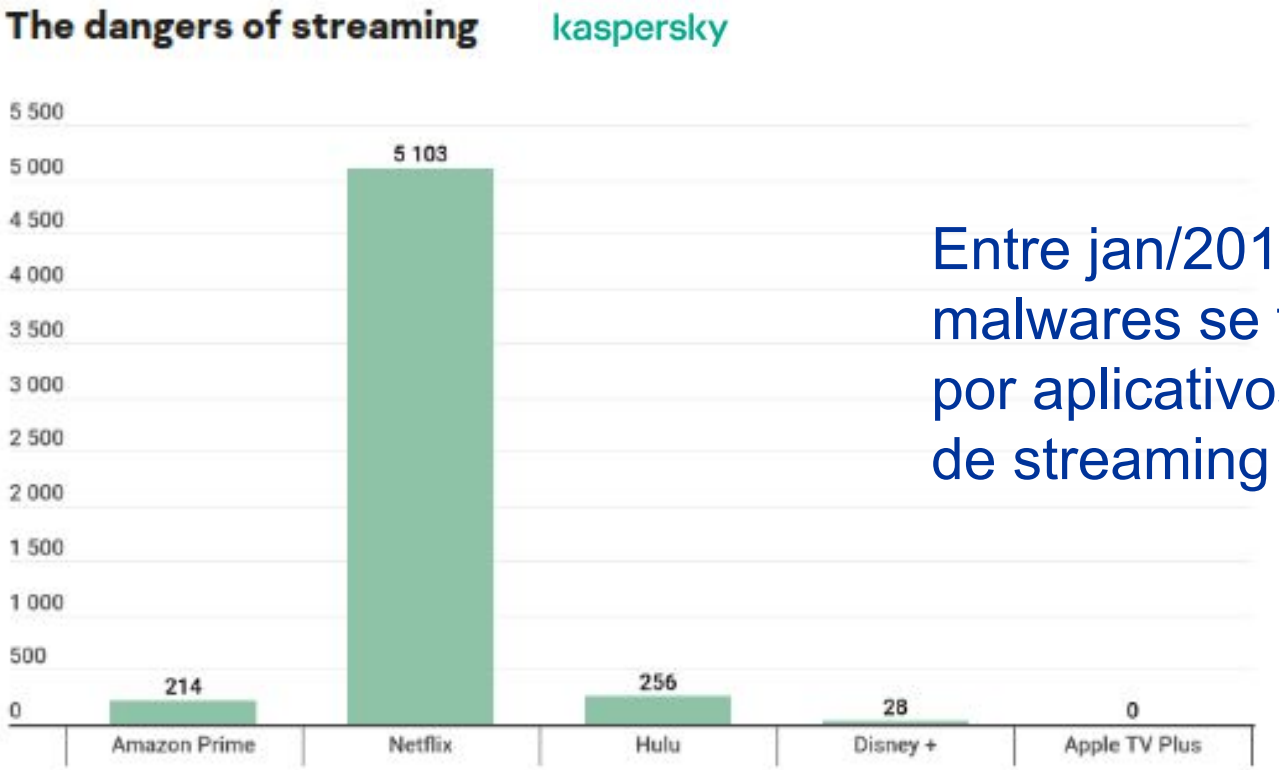


Gráfico mostra grande aumento de novos malwares visando aplicativos de celular para bancos em 2023

Fonte: https://securelist.com/it-threat-evolution-q3-2023-mobile-statistics/111224/

Ameaça durante a diversão



Entre jan/2019 e abr/2020 malwares se fazem passar por aplicativos de plataformas de streaming de vídeo

Fonte: https://securelist.com/it-threat-evolution-q3-2020/99382/

Ameaças não param

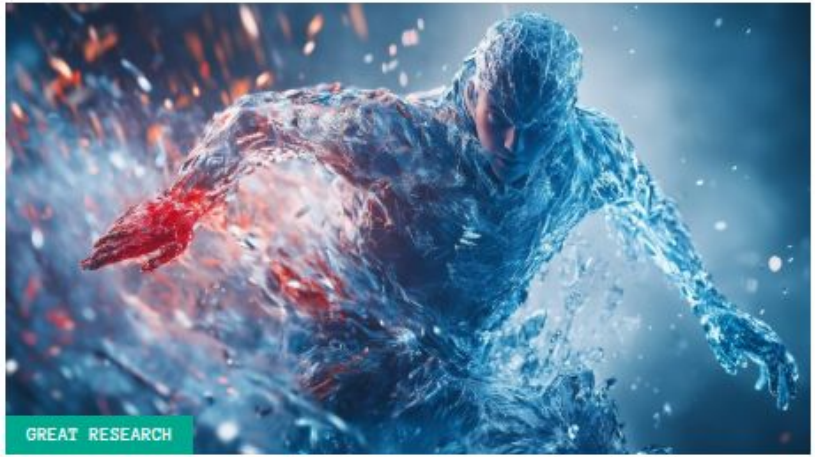
SECURELIST by Kaspersky

The HoneyMyte APT evolves with a kernel-mode rootkit and a ToneShell backdoor

NOUSHIN SHABAB

Threat landscape for industrial automation systems in Q3 2025

KASPERSKY ICS CERT



HoneyMyte updates CoolClient and deploys multiple stealers in recent campaigns

Malwares e estratégias de disseminação se renovam a cada ano

Fonte: https://securelist.com/

Objetivo Geral

Visão geral sobre segurança, para que o aluno saiba como prevenir, defender e resolver incidentes de segurança

do ponto de vista de um profissional de segurança

Objetivos Específicos

- Compreender os principais riscos e **vulnerabilidades de segurança;**
- Conhecer as **normas, procedimentos e políticas** para gerenciamento de segurança da informação;
- Conhecer principais **aplicativos** relacionados a segurança;
- Conhecer os principais **problemas e soluções** no desenvolvimento de aplicações seguras;
- Utilizar **ferramentas** de segurança de dados.

Ementa

- Introdução à segurança de computadores
- Algoritmos e ferramentas de criptografia
- Autenticação de usuários e controle de acesso
- Firewalls
- Sistemas de prevenção de intrusão e detecção de intrusão
- Computação confiável
- Segurança em software e programação segura
- Problemas de gerência da segurança
- Segurança na Internet e em Sistemas Operacionais

Metodologia

- Aulas expositivas e demonstrativas (professor)
- Aulas práticas / Relatórios Técnicos (professor e alunos)
- Ferramentas e técnicas de proteção
- Seminário (alunos)
- Tema relacionado a segurança
- Pesquisa constante
- Pesquisa de livros, sites, técnicas, ferramentas, incidentes, etc.
- Preparação de resumos
- Discussão em aula

Créditos (TPEI: 3-1-0-4)

Cada disciplina na UFABC é representada por três algarismos: T – P – E – I

Para a disciplina **MCTA023-17**:

T: 3h – Número de horas semanais de aulas expositivas presenciais da disciplina (Teóricas);

P: 1h – Número de horas semanais de trabalho de laboratório, aulas práticas ou de aulas de exercícios, realizadas em sala de aula (Práticas);

Laboratório a cada quinzena, com 2h

E: 0h – Sem horas de atividades de extensão universitária.

I: 4h – Estimativa de horas semanais adicionais de trabalho necessárias para o bom aproveitamento da disciplina (estudos e trabalhos Individuais).

Recomendações para Segurança Dados

Ter cursado as disciplinas:

- Programação Estruturada (ou Algoritmos e Estruturas de Dados I)
- Redes de Computadores
- Indicar seu caso, para cada disciplina (PE, AED1, RC, AA, BD, SO):

  `aprovado; cursando; não fez`

Disciplina obrigatória do Bacharelado em Ciência da Computação

- Último quadrimestre: melhor aproveitamento

Horários e Locais - Turma Diurno 2026.Q1

Aulas teóricas: sala **S-214-0**

- terças, das 19:00 às 21:00 (semanal)
- quintas (quinzenal I), das 21:00 às 23:00

Aulas práticas:

- quintas (quinzenal II), Laboratório **405-2**, em dois horários:
  - Turma NA1 - das 19:00 às 21:00
  - Turma NA2 - das 21:00 às 23:00

Atendimento Extraclasse

Mensagens via **Moodle**, usando seu login institucional:

- **Evite** escrever diretamente para meu email (fora do Moodle), pois não garanto retorno

Atendimento presencial:

- quintas, das 16:00 às 18:00, sala 533-2
  - agendar com antecedência, via **Moodle**, ou confirmar na aula

Materiais e Atividades no Moodle

https://moodle.ufabc.edu.br/

Basta entrar com seu login institucional da UFABC e acessar a disciplina:

SD-2026q1

Itens de Avaliação

- Prova escrita 1 (**P1**): **09/04/2026** 25%
- Prova escrita 2 (**P2**): **23/04/2026** 25%
- Trabalho de pesquisa (T) 25%
- Atividades de Lab e exercícios (L) 25%

- Se aproveitamento em P1, P2, T ou L for igual a **0%**,
  - conceito pré-recuperação será no máximo igual a **D**, independente do aproveitamento nos demais componentes avaliativos

Itens de Avaliação

Prova Substitutiva **28/04/2026**

- somente para quem perdeu uma prova (se enquadra na resolução ConsEPE 181)
- engloba todo o conteúdo
- substitui apenas uma prova

Mecanismo de Recuperação **05/05/2026**

- somente para quem ficou com conceito D ou F (resolução ConsEPE 182)
- engloba todo conteúdo; composto com conceito pré-Rec (50%)

Conceitos

A: desempenho excepcional, demonstrando excelente compreensão da disciplina

B: bom desempenho, demonstrando capacidade boa de uso dos conceitos da disciplina

C: desempenho adequado, demonstrando capacidade de uso dos conceitos da disciplina e capacidade para seguir em estudos mais avançados

D: aproveitamento mínimo dos conceitos da disciplina, com familiaridade parcial do assunto, mas demonstrando deficiências que exigem trabalho adicional para prosseguir em estudos avançados

F: reprovado. A disciplina deve ser cursada novamente para a obtenção de crédito

O: reprovado por falta. A disciplina deve ser cursada novamente para a obtenção de crédito

Trabalho e Seminário

Divisão da turma em grupos

Todos participarão de duas avaliações:

- Parte escrita (60%):
  - tema descrito em forma de artigo científico
  - texto será revisado e distribuído para toda turma (conteúdo será incluído na Recuperação)
- Parte oral (seminário, nota individual - 40%):
  - apresentação (slides) por todos da equipe

Trabalho e Seminário - Temas (1)

- Malware (G1)
- DDoS (G2)
- Segurança em Sistemas Operacionais (G3)
- Segurança em SO específicos: Linux e Windows (G4)
- Segurança em Banco de Dados (G5)
- Desenvolvimento Seguro de Software (G6)
- Segurança em aplicações Web (G7)
- Desenvolvimento Seguro de aplicações Web (G8)
- Defesa cibernética (G9)
- Blockchain: conceitos e segurança (G10)

Trabalho e Seminário - Temas (2)

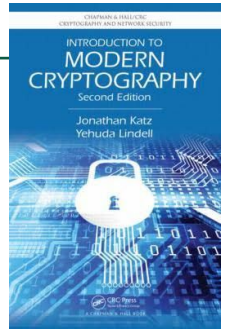
- Criptografia pós-quântica baseada em reticulados: assinatura (G11)
- Criptografia pós-quântica baseada em reticulados: PKE/KEM (G12)
- Criptografia pós-quântica baseada em códigos: PKE/KEM (G13)
- Hash criptográfico SHA-3 (G14)
- LGPD - Lei Geral de Proteção de Dados Pessoais no Brasil (G15)
- Normas e Gestão de Segurança (G16)
- Aspectos Humanos na Segurança da Informação (G17)
- Firewall (G18)
- Detecção de Intrusão - IDS (G19)
- **Sua proposta** (G20 em diante)
  - Artigo científico a ser explorado pelo grupo (mediante aprovação)

Plano de Aulas (sujeito a ajustes)

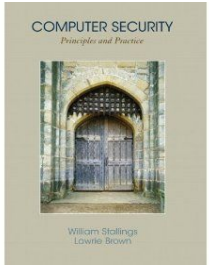
Semana	Terça (só Teoria, sala 214-0)		Quinta (T: sala 214-0 quinz-I; L: Lab 405-2 quinz-II)		
1	3/fev.	Apresentação da disciplina, Introdução a Segurança de Dados	5/fev.	T	Introdução a criptografia (cifras clássicas)
2	10/fev.	Introdução a criptografia (cifras de fluxo, cifras de bloco, modos de operação).	12/fev.	L	Prática: preparo do ambiente (Seed Labs) e criptanálise de frequência
3	17/fev.	Carnaval	19/fev.	T	Criptografia Assimétrica: conceitos, RSA encriptação (confidencialidade)
4	24/fev.	Criptografia e integridade: hash, código de autenticação de mensagem. Protocolo de acordo de chave: Diffie-Hellman	26/fev.	L	Prática: criptografia simétrica
5	3/mar.	Criptografia assimétrica (RSA assinatura, autenticidade de origem, PKI)	5/mar.	T	Controle de acesso e Autenticação de usuário
6	10/mar.	Framework TLS.	12/mar.	L	Prática: criptografia assimétrica
7	17/mar.	Programação segura (buffer overflow, string de formatação)	19/mar.	T	Programação segura (SQL Injection, XXS)
8	24/mar.	Apresentação de trabalhos (Seg. SO específicos, Desenv. Seguro de Software)	26/mar.	L	Prática: segurança no software
9	31/mar.	Apresentação de trabalhos (malware, Desenvolvimento Seguro de aplicações Web)	2/abr.	T	Apresentação de trabalhos (seg. SO, Seg. aplicações Web, LGPD)
10	7/abr.	Apresentação de trabalhos (DDoS, Criptog. baseada em códigos, normas e gestão da segurança)	9/abr.	L	**Prova P1**
11	14/abr.	Apresentação de trabalhos (Blockchain, Defesa cibernética e Segurança em BD)	16/abr.	T	Apresentação de trabalhos (SHA3, Criptografia baseada em reticulados, Firewall)
12	21/abr.	Feriado de Tiradentes	23/abr.	L	**Prova P2 (conteúdos dos seminários)**
13	28/abr.	Prova Substitutiva (reposição de 17/fev)			
14	5/mai.	Mecanismo de Recuperação (reposição de 21/abr)			

Referências básicas

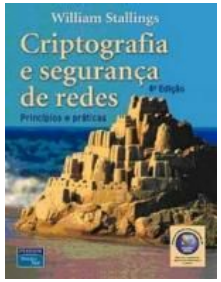
- Katz, J; Lindell, Y. Introduction to Modern Cryptography. CRC Press. 2014.



- Stallings, W., Brown, L. Computer Security: Principles and Practice, ed. Prentice Hall, ISBN-13: 9780136004240



- Stallings, W. Criptografia e segurança de redes – Princípios e Práticas, 4 edição, ed Prentice Hall - ISBN 8576051192



Introdução a Segurança de Dados

Segurança para proteger o quê?

Para **Proteger Valores**

- Exemplo: Instituição Financeira
  - Antigamente, os ativos eram físicos: papel moeda, ouro, etc
  - Em tempos atuais, os ativos são essencialmente digitais:

Dados, Informação

- Em computação, busca-se proteger dados, ou seja, criar mecanismos de segurança para um sistema computacional

Como Definir Segurança de Dados?

- A maneira como definimos Segurança de Dados norteia a construção de métodos para sua proteção

- Seguiremos uma definição que se tornou clássica, sob a qual serão discutidas as questões de segurança, tecnologias e ferramentas ao longo da disciplina

Segurança de Dados - Definição

- O National Institute of Standards and Technology (NIST) Computer Security Handbook define o termo Segurança de dados:

> Proteção a um sistema de informação automatizado, a fim de atingir os objetivos aplicáveis de preservar a integridade, disponibilidade e confidencialidade das fontes de informação do sistema (inclui hardware, software, firmware, informações/dados e telecomunicações).

Guttman e Roback. An Introduction to Computer Security: The NIST Handbook. Disponível em: https://www.nist.gov/publications/introduction-computer-security-nist-handbook

Proteger tudo?

Sim, mas antes é preciso classificar esse “tudo”

Exemplo: Ativos de instituições financeiras:

- Papel moeda (concreto): valor alto
- Sistema de Informações do Banco: valor variável (de baixo a muito alto)
  - Algumas informações são tratadas como sigilosas (alto valor)
  - Outras informações podem gerar pouca ou nenhuma consequência caso sejam roubadas (baixo valor)

Tipo de informação

Pública – informação que pode vir a público sem consequências danosas ao funcionamento normal da empresa;

Interna – o acesso a esse tipo de informação deve ser evitado, embora as consequências do uso não autorizado não sejam por demais sérias;

Confidencial – informação restrita aos limites da empresa, cuja divulgação ou perda pode levar a desequilíbrio operacional, e eventualmente, perdas financeiras;

Secreta – informação crítica para as atividades da empresa, cuja integridade deve ser preservada a qualquer custo e cujo acesso deve ser restrito a um número bastante reduzido de pessoas.

Os Fatores de Risco

Falta de consciência das ameaças e riscos do sistema de informação:

- As medidas de segurança muitas vezes não são consideradas até que uma empresa seja invadida por usuários mal-intencionados

Políticas de rede

- Muitos sites permitem acessos sem controle

Grande parte do tráfego da rede não é protegido (criptografado)

- O tráfego de rede pode ser monitorado, capturado ou adulterado

Ameaças, vulnerabilidades e controles

Vulnerabilidade

- Fraqueza no sistema de segurança que pode ser explorado para causar perda ou dano
- Exemplo: sistema sem autenticação para acesso aos dados

Ameaça

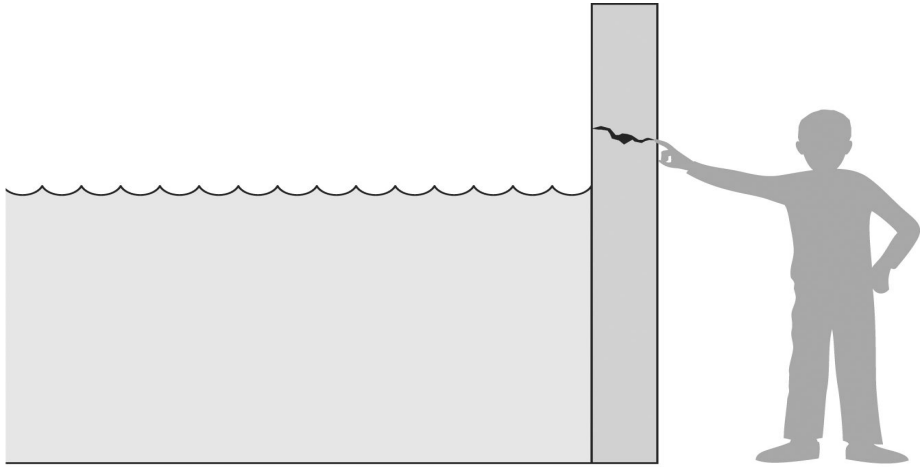
- Conjunto de circunstâncias que tem potencial para causar perda ou dano
- Risco: a possibilidade de ameaça de causar danos

Controle

- Uma medida de proteção
- Uma ação, procedimento, técnica que remove ou reduz uma vulnerabilidade

Ameaças, vulnerabilidades e controles

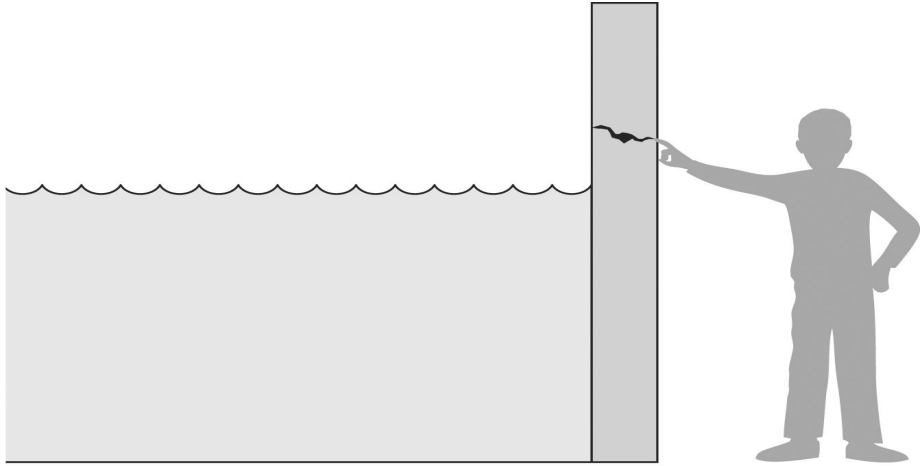
- Ex: uma barreira está segurando a água (ou rejeitos contaminados)
- **O que pode acontecer com o homem?**



Risco: possibilidade de morte, caso a **ameaça** de rompimento se concretizar

Ameaças, vulnerabilidades e controles

Ex: **ameaça** de rompimento pode existir, dadas as condições de projeto, de execução de obra ou de manutenção, que podem inserir **vulnerabilidades** ao sistema. Inspeções de rotina e contramedidas são **controles** de vulnerabilidades

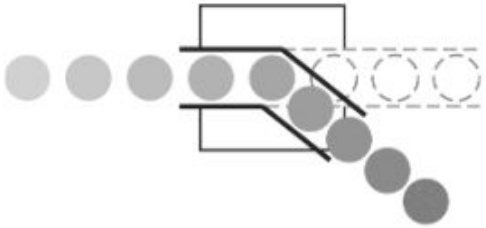


Uma ameaça é bloqueada pelo controle de vulnerabilidade

Ameaças à segurança

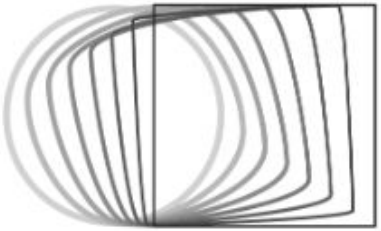
4 tipos de ameaça:

- Interceptação
- Interrupção
- Modificação
- Fabricação

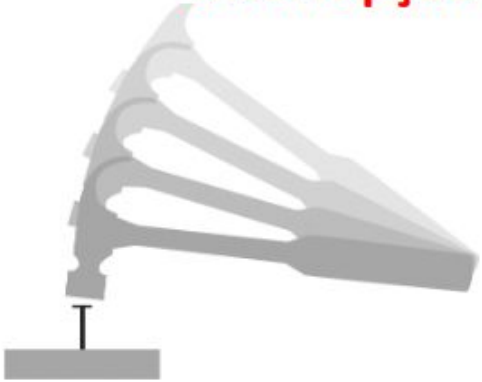


Interceptação

Interrupção



Modificação



Fabricação

Exemplos de Ameaças

Interceptação

- Acesso não autorizado: cópias ilegais de programas ou escutas

Interrupção

- Perda de um arquivo: destruição de hardware

Modificação

- Modificação não autorizada: mudança do Banco de dados

Fabricação

- Criação não autorizada: adição de um Registro no BD

Ataque à segurança

Ameaça inteligente, em ação

Ato inteligente que é uma tentativa deliberada de burlar os serviços de segurança e violar a política de segurança de um sistema

Método, Oportunidade, Motivo

Um atacante deve ter três coisas:

- Método: as competências, conhecimentos, ferramentas e outras coisas com o qual é capaz de obter sucesso no ataque
- Oportunidade: o tempo e acesso para realizar o ataque
- Motivo: uma razão para querer executar este ataque contra o sistema

(Pense na sigla "MOM")

Negar qualquer uma dessas três coisas pode permitir que o ataque não ocorrerá. No entanto, não é fácil controlar

Objetivos de Segurança (3 mais Básicos)

Confidencialidade (Secrecy)

– A informação somente pode ser acessada por pessoas explicitamente autorizadas

Integridade

– A informação deve ser restaurada em sua forma original

Disponibilidade

– A informação ou sistema de computador deve estar disponível no momento em que a mesma for necessária

Desafio: é necessário encontrar um certo equilíbrio entre esses objetivos, que frequentemente são conflitantes

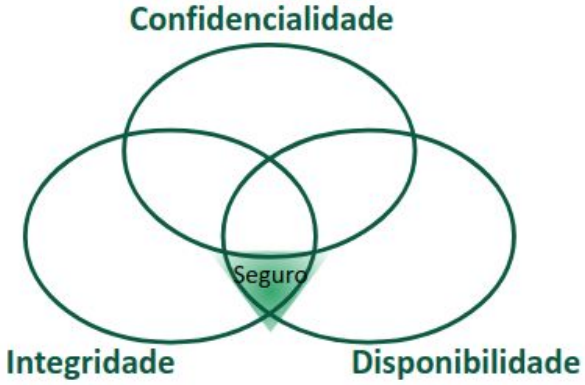
Relação entre os objetivos de segurança

Os 3 objetivos podem:

- ser independentes
- podem se sobrepor ou
- ser mutuamente exclusivos

Ex:

- Sistema financeiro com os 3 objetivos
- Portal web com 2 objetivos



Exemplo: Aplicação comercial

Confidencialidade - um funcionário de mais baixo escalão não deve saber o salário de seu diretor;

Integridade - um funcionário não deve ser capaz de modificar o próprio salário;

Disponibilidade - os pagamentos deverão ser emitidos a qualquer momento conforme estipulado por lei

Exemplo: Aplicação militar

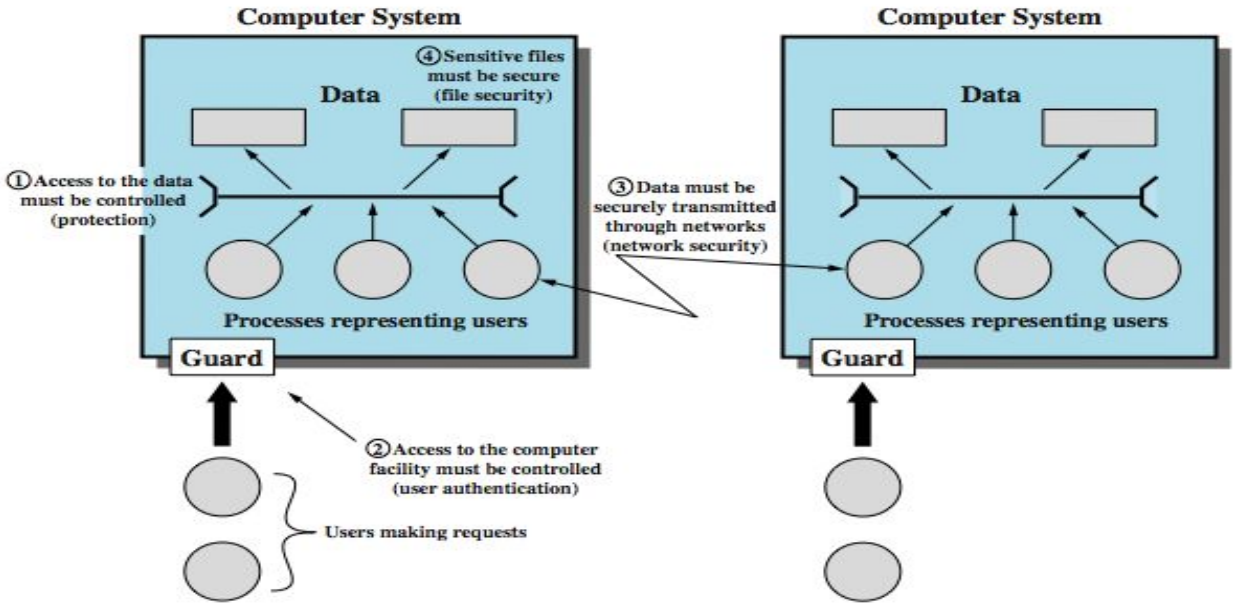
Confidencialidade - as coordenadas do alvo de um míssil não devem ser indevidamente divulgadas

Integridade - as coordenadas de um míssil não devem ser modificadas indevidamente

Disponibilidade - quando o comando apropriado é enviado, o míssil deve ser disparado

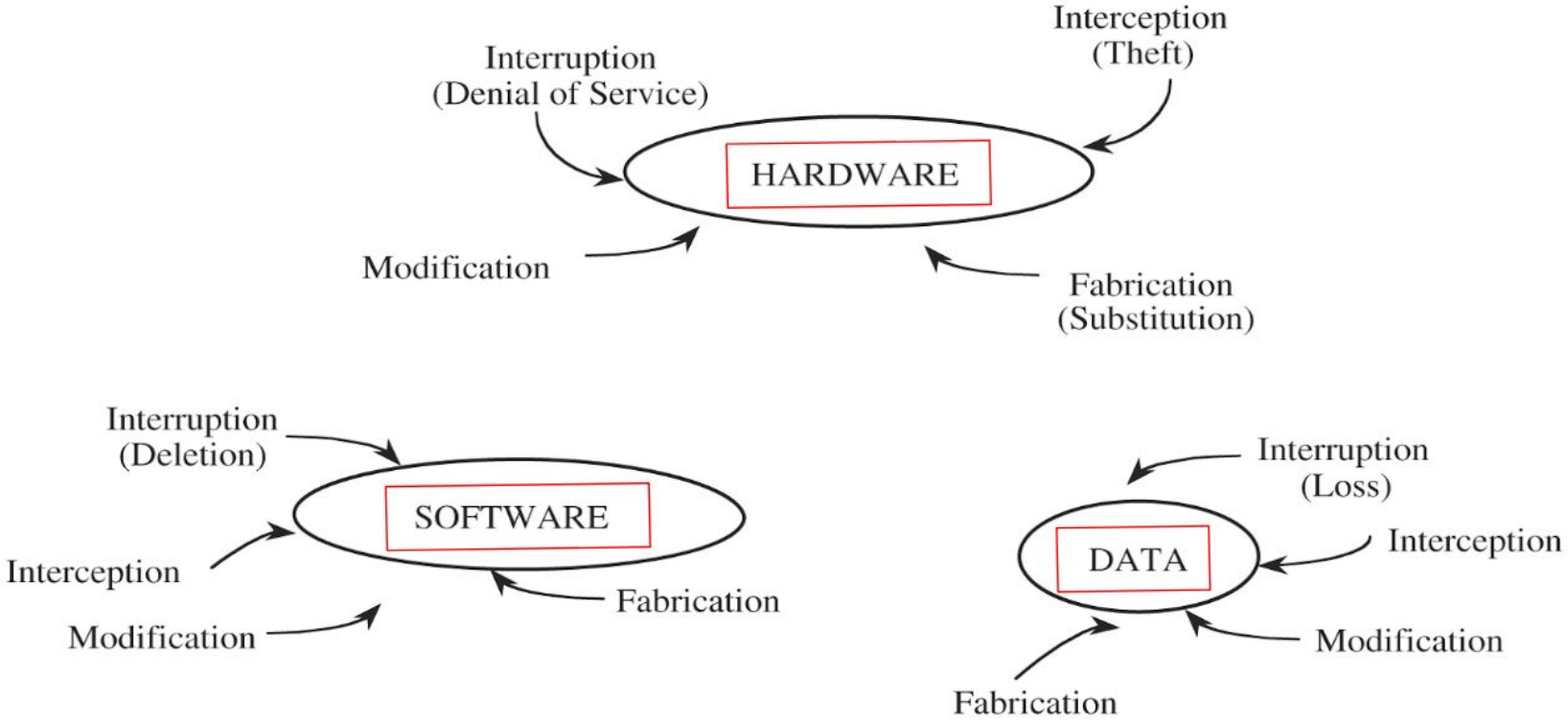
Segurança em Sistemas computacionais

Inclui variados níveis: nos processos, nos arquivos, nos vários dispositivos, na comunicação



Alvos de Ameaças

Dados, Software e Hardware são alvos nas 4 formas de ataque



Alvos de Ameaças

Exemplos para Software:

Confidencialidade – uma cópia não autorizada do software é realizada

Integridade – um programa é modificado para causar falha durante execução

Disponibilidade – programas são apagados, assim como acesso negado.

Pontos de Vulnerabilidade

Hardware – Dispositivos móveis são mais vulneráveis, porque eles são projetados para serem de fácil transporte

Software – Pode ser substituído, alterado, destruído, modificado, excluído ou extraviado acidentalmente. Se intencional ou não, esses **ataques exploram vulnerabilidades do software**.

Agentes de Crimes Computacionais

Amadores

- Pessoas normais que descobrem ter acesso a “algo” valioso
- Costuma ser principal fonte para crimes computacionais

Crackers

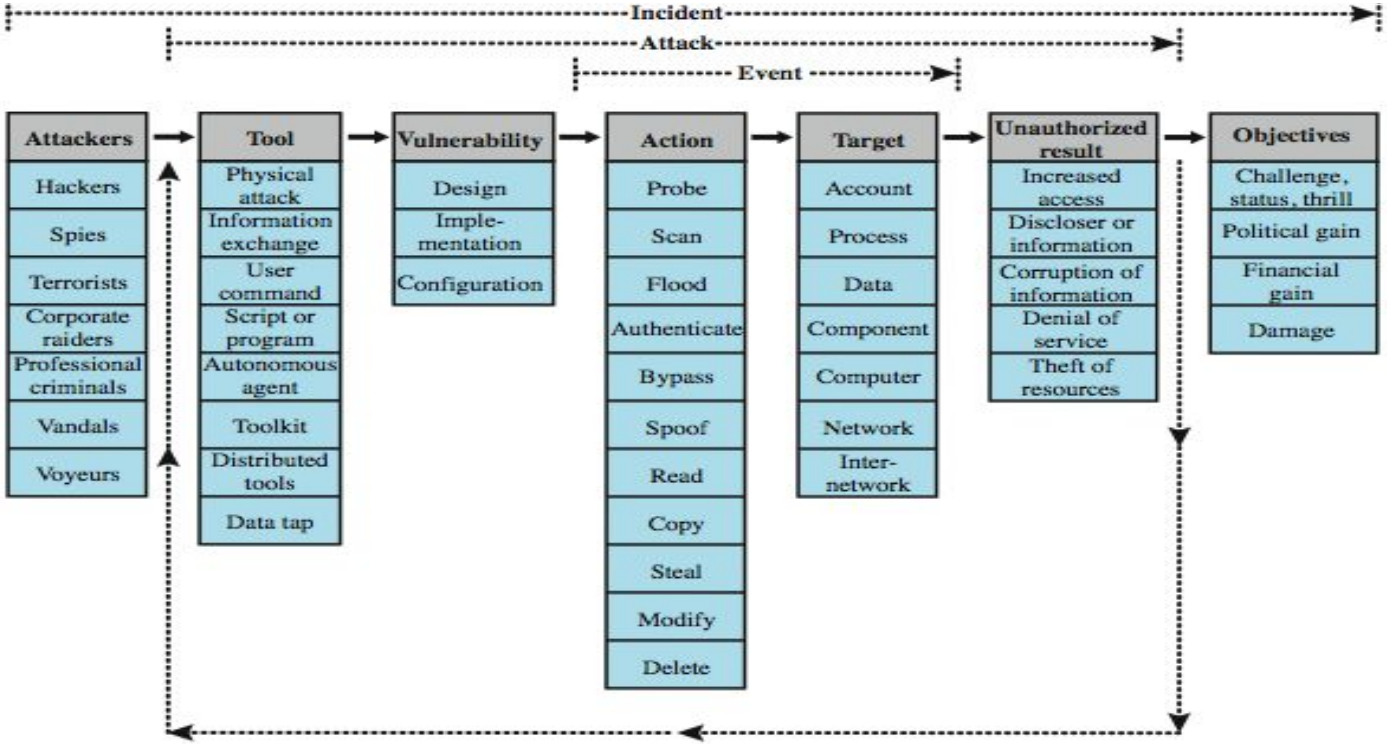
- Pessoas que “quebram” a segurança de um sistema com objetivos ilegais

Profissionais criminosos

- Profissionais de computação em quadrilhas envolvidas em crimes computacionais
- Spam, phishing, crimes de cartão de crédito, …
- Atualmente, uma das principais fontes de crimes eletrônicos

Incidentes de Segurança

Taxonomia de ataques e incidentes em rede e computadores



Estratégias de segurança

Política de segurança

- O que proteger?
- Quais controles?

Implementação e mecanismos de segurança

- Como?

Garantia de Segurança

- Funciona?
- Quanto?

Política de segurança

Envolvem todos os controles da organização, manuais e automatizados, que afetam as atividades dos Sistemas de Informação

Política de segurança

Fatores a serem considerados:

- O valor dos bens a serem protegidos
- As vulnerabilidades do sistema
- Ameaças potenciais e ataques possíveis

Balancear:

- Facilidade de uso X Nível de segurança
- Custo da segurança X Custo da falha e de recuperação

Política de segurança

Política de segurança:

- é decisão administrativa, de negócio
- pode ser influenciada por requisitos legais

Implementação e Mecanismos

Prevenção

- prevenir que um ataque seja bem sucedido

ex: controle de acesso ou cifras previnem ataque confidencialidade

Detecção

- Identificar, por ex., um acesso não autorizado

Resposta

- se um mecanismo detecta um ataque em andamento, deve reagir

Recuperação

- ex: dano de integridade deve ser corrigido (backup)

Mecanismo de segurança

Implementa funções que ajudam na

prevenção, detecção, resposta e recuperação

relacionados a possíveis ataques

Funções de segurança

são normalmente disponibilizadas para os usuários como um

conjunto de serviços de segurança através de

APIs ou interfaces integradas

Mecanismos: Formas de Controle

Criptografia - fundamental para quase todos os mecanismos

Hardware e Software de controle

- Exemplos: Controles de sistemas operacionais, firewalls

Políticas e procedimentos

- Exemplo: política de mudanças de senha

Controle físico

- Exemplos: guardas e portas trancadas

Mecanismos Específicos

- Cifragem
- Assinatura digital
- Controle de acesso
- Mecanismos de Integridade de dados
- Mecanismos de Autenticação
- Controle de roteamento
- Certificação

→ Serão estudados em aulas futuras

Serviços de Segurança (X.800)

Quando há **Comunicação**, os requisitos básicos são ampliados:

- Autenticação de entidade; de origem de dados
- Controle de Acesso: cada entidade deve ser identificada e autenticada
- Confidencialidade de Dados: proteção dos dados contra ataques passivos e análises
- Integridade de Dados: proteção dos dados em transmissão, contra modificação, fabricação, reordenação, repetição
- Irretratabilidade: impedir que uma entidade negue uma operação realizada (non-repudiation)
- Disponibilidade: um recurso ou serviço deve estar disponível

Eficiência dos controles

Consciência do problema

- Profissionais que usam mecanismos de controle devem estar convictos de sua necessidade para segurança

Probabilidade de uso

- Controles devem ser **eficientes**, **fáceis** de usar e apropriados para o problema (**custo** condizente)

Sobreposição de controles

- Combinação de controles para solucionar uma simples vulnerabilidade
  - Camadas de defesa
- Avaliação da eficiência do controle deve ser uma tarefa contínua
  - Revisões periódicas

Garantia da segurança

Com que eficiência o mecanismo de segurança garante a política determinada?

- Todos buscam ter alta garantia
- Mas alta garantia implica e elevação de custo
  - Talvez isso não seja possível
- Escolhas são necessárias
  - **Equilíbrio** é a palavra-chave

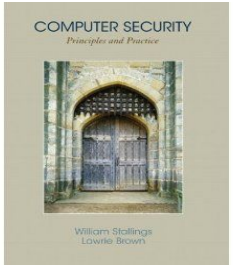
O Elo mais Fraco

- Segurança deve ser vista como uma **corrente** de proteção:
  - é um **conjunto de elos** que garante a proteção geral
  - é o elo mais fraco que tem mais chance de se partir

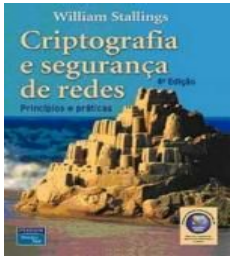
Estudo Individual

Leituras Sugeridas

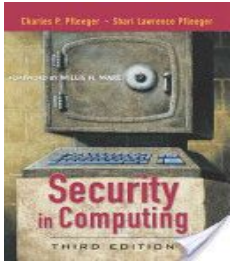
Stallings, W., Brown, L. Computer Security: Principles and Practice, ed. Prentice Hall, Capítulo 1.



Stallings, W. Criptografia e segurança de redes – Princípios e Práticas, 4 edição, ed Prentice Hall, Capítulo 1.



Charles P. Pfleeger and Shari L. Pfleeger. Security in Computing (3 nd edition). Prentice-Hall. 2003. ISBN: 0-13-035548-8.



Questões de Autoavaliação

(não precisa entregar)

Questões

1- Diferencie: vulnerabilidade, ameaça e controle.

2- Em relação aos ativos de um sistema computacional podemos categorizar hardware, software, dados, linha de comunicação e redes de computadores. Descreva os elementos em relação aos conceitos de integridade, confidencialidade e disponibilidade.

3- Roubo normalmente resulta em algum tipo de dano. Por exemplo, se alguém rouba o seu carro, você pode sofrer perdas financeiras, inconveniente (por perder o seu modo de transporte), e distúrbios emocionais (por causa da invasão de sua propriedade pessoal e espaço). Liste três tipos de danos que uma empresa pode ter por roubo de equipamento de informática.

4- Dê um exemplo de uma situação em que um compromisso de confidencialidade conduz a um compromisso de integridade.

5–Defina resumidamente as categorias de serviço de segurança de sistemas em rede.

6- Dê exemplos para os quatro tipos de ameaça para hardware e dado.